

FAQ – Security Risk Assessment – Chemical AI Inc.

1	Certifications & Policies	
1.1	Are any standards-based certifications maintained? If so, which ones? (E.g., ISO, etc.)	ISO 9001 and 27001
1.2	Describe the insider threat program active within the company?	• Prevention Code Review and Vulnerability Management: SonarQube is integrated into the CICD flow to review submitted code and identify and fix potential security vulnerabilities. After the release is finalized, the built container images are scanned using Trivy automation tool to scan the images and the latest real-time CVE vulnerability repository to analyze potential security vulnerabilities and fix them before the release. The quality management team regularly performs security vulnerability scans on both pre-release and online environments to ensure that unexpected security vulnerabilities can be found and fixed in a timely manner. • Monitoring A monitoring system is deployed in the formal environment to monitor business, system logs and network traffic in real-time and configure timely alert notifications. Intrusion detection and firewalls are deployed at the network and hardware levels to detect abnormal behavior in a timely manner. In response to threat intelligence, subscribe to the latest threat intelligence feeds to learn about currently active malware, vulnerability exploits, and other information, and adjust security policies to address new threats. • Incident Response A professional incident response team is set up to monitor and alert the main recipients and observers of information, responsible for monitoring, identifying and responding to security threats. Team members include security experts, operations and maintenance personnel, and development leaders. Clearly formulated emergency response process, including steps such as incident categorization, initial assessment, threat isolation and impact mitigation. Analysis and improvement will also be carried out afterwards to thoroughly investigate security incidents, analyze the causes, and optimize existing security policies and response plans. • Emergency Recovery

		Data Backup and Disaster Recovery: The online formal environment is set up with a regular data backup policy and stored in multiple physically isolated availability zones to ensure the safety and backup reliability of business-critical data. Operations such as emergency recovery and system rebuilding for failures are practiced from time to time to ensure the recoverability and availability of backups.
--	--	--

2	Audit	
2.1	How are audit logs stored? (E.g., who logged in at what time) How can they be reviewed by the client for review?	Audit logs will be stored in exclusive database, only audit administrator can access it, it's a one-time privilege which approved by CEO with business reasons. The client's tenant administrator can submit a request to corresponding Business Directors for requesting the audit log review for the client.
2.2	Can SOC (Service Organization Controls) reports be provided to the client? SOC 1 – Related to Internal Control over Financial Reporting SOC 2 – Related to testing over the Trust Services Principles of Security, Availability, Processing Integrity, Confidentiality, and Privacy SOC 3 – A simplified report on the same principles in SOC 2 and available for public use Vendors management assertion	We do not have the SOC 2 certification yet, because most of our clients choose local deployment rather than a SaaS over internet.
2.3	Additional Comments	If you need to deploy ChemAIRS locally, you don't have to worry about data security issues. ChemAIRS supports a completely private deployment and runs in an intranet environment with no Internet access after deployment, and the entire system is under your management and control, whether it's to the hardware, the application, or the system, all under your control.

3	Data Protection	
3.1	What data-encrypted measures are used during transit? Specify version if applicable.	1. TLS 1.3 (preferred) and 1 2. AES 256
3.2	What data-encrypted measures are used at destination (at rest)?	1. Private encryption algorithm 2. Hashed and salted format
3.3	During the first-time data transfer (pre-load), how is the data encrypted?	ChemAIRS use enforced HTTPS protocol to ensure that requests are not coming from unauthorized access and uses TLS encryption during transmission to secure the content of the transmitted data

3.4	Where is data located/stored?	All the data stored in database server on AWS, North California (us-west-1). If the local deployment is selected, all the data store in customer's storage.
3.5	What Personally Identifiable Information (PII) is stored outside of Canada? <i>PII is defined as information: that directly identifies an individual (name, address, social security number or other identifying number or code, telephone number, etc.)</i>	Name, email and company name.
3.6	How is access to the data restricted?	The ChemAIRS system is deployed in a private account cloud environment with only limited access granted to privileged accounts. System administration and maintenance privileges (excluding data access) are granted to authorized system administrators. Data access privilege is one-time privilege, and each access privilege requires submission of a business justification and authorization by the CEO. Accounts managing the system will not have access to specific data and will only be able to maintain application components such as the system, network and database engines. The entire system will only provide basic business system access to the external development of Web services, other external access channels are closed, all other services are only internal accessible, administrators through the cloud environment management platform to log in and manage, data access privileges account is also the same, all access, operation records are retained and used as the basis for auditing.
3.7	How is the data segregated from other clients' data?	In the SaaS environment, different customers realize independent storage and access through tenant segregation, and different tenants cannot access each other.
3.8	How is data deleted if no longer required?	In the SaaS environment, if the customer needs to delete data, then we need the person in charge or administrator of the customer's tenant to send a data deletion request that has been authorized by the customer internally, which will be audited by ChemAIRS's data security team, submitted to the operator and authorized to the CEO. After that, during the database maintenance time period (usually the time period of the low usage rate), the system administrator will operate the backup database first and confirm the success, and finally during the database maintenance period (usually during low usage hours), the system administrator will first operate the backup database and confirm its success, and then finally, the data will be deleted by the manager who has been granted data access and operation rights. In the local deployment, that's all managed by customers.

3.9	On what frequency are regular backups performed? How are the backups tested?	ChemAIRS database running in AWS RDS which provide Data integrity and high availability assurance, the full backups are performed on a daily basis, after which copies of the data are re-created and continue to be dumped into a dedicated storage server. The quality management team performs automated recovery tests on the backup copies on a regular basis to verify the availability of the recovered system under a proprietary tenant using a dedicated account for testing, in addition to verifying data integrity and recoverability.
3.10	What happens to the data at termination of the agreement? (E.g., how is data returned to The client and/or destroyed)	In the current version, expired user accounts and their data will not be deleted or returned automatically. If an expired user account needs to delete the data belonging to them, they need to take the initiative to submit a request to the ChemAIRS team, and we will perform the deletion operation only after receiving and reviewing the request. The function of automatic data removal for expired accounts is under development, and users will be notified in advance of account expiration and data deletion and other sensitive operations.
3.11	Describe the disaster recovery plan in place? How will the client be notified if there is a disaster recovery event?	ChemAIRS is deployed in AWS and runs in high availability SaaS services provided by cloud providers such as RDS, EKS, etc., with multi-copy instances in different availability zones to guarantee fast recovery and switching in case of disaster. In the unfortunate event that the high availability service provided by the cloud provider fails to provide the appropriate availability guarantee, our application and data separation and distributed containerized architecture can also be quickly recovered in a newly built cluster. In the event of a catastrophic failure, the ChemAIRS team will send notification emails to the relevant users through the Ops system, and the client's dedicated business manager will be contacted individually to disclose the latest progress and solutions to the client.
3.12	How is The client notified of a data or system breach?	In the event of a catastrophic failure, the ChemAIRS team will send notification emails to the relevant users through the Ops system, and the client's dedicated business manager will be contacted individually to disclose the latest progress and solutions to the client.
3.13	What process is in place for notifying The client of a change in location of the data storage?	If a data breach occurs, the ChemAIRS team will send a notification email to the relevant users via the Ops system and the client's dedicated Business Manager will be contacted individually to disclose the latest progress and resolution to the client.

4	Systems and Networks	
4.1	Which third-party data center is used? (Co-location, Azure, AWS, etc.)	In AWS
4.2	If applicable, what are the physical access restrictions to the data center?	Internal only private network (VPC) based cluster deployment and limited authorized AWS management platform access.
4.3	If applicable, how are data centers monitored?	Integrated AWS CloudWatch and self-hosted Prometheus & Grafana monitoring system in EC2 instances
4.4	If applicable, how is hardware kept up to date?	ChemAIRS is based on the Kubernetes distributed container architecture, the underlying server can be very easy to expand and shrink the capacity, also includes changing the server instance to a newer hardware model.
4.5	If applicable, how is hardware and/or data storage decommissioned?	Please refer to 4.4.
4.6	Describe the separation of the production system environment (DEV and QA)?	DEV, Test and QA environments run on our own physical servers hosted in the data center, while pre-release environments are deployed in proprietary test clusters under the same AZ, exactly replicating the base settings of the official environment to ensure that no unexpected failures will occur due to differences in the environments.
4.7	During upgrades, how are vulnerabilities discovered before production deployment?	ChemAIRS accesses SonarQube's quality management and vulnerability detection engine at code compilation time (CICD). Vulnerabilities in the reference chain are identified in daily reports and reviewed by the code security team before being submitted to the code owner for repair, and only after the repair is complete will the merge-in request be approved. At release time, the code artifact will be built as a container image and released to the pre-release project. In the privately deployed Harbor repository, we use the Trivy engine to scan the image, and once a risky vulnerability is found, it will be reviewed by the code security team and submitted to the Devops administrator for fixing. After the release of the version we will also quality management team is also for the pre-release environment and online formal environment from time to time security scanning, once any problem is found will be reported to the code security team to review and submit to the person in charge of the corresponding repair.
4.8	At what frequency, and how is patching on systems and software performed?	There is no fixed frequency for system updating patches, as the infrastructure runs in an EC2 instance of AWS, the frequency of patch updates is determined by the AWS push mechanism.

		Applications are built as container images whose patches are typically updated automatically with each version release, usually at a frequency of once a month.
4.9	Describe the intrusion detection system in place?	We are using the AWS GuardDuty. https://docs.aws.amazon.com/guardduty/latest/ug/what-is-guardduty.html
4.10	Are firewalls in place to only allow the minimum ports required?	YES. Only 443 and 80 is allowed. ChemAIRS is HTTPS only, but we still keep the 80 port open to redirect all HTTP traffic into HTTPS in force.
4.11	Can the service restrict access to client's IPs? If yes, how?	YES, via AWS security group (Also used in ELB)
4.12	Describe any input validation to prevent code injections? (Web forms, API calls, etc.)	1. Strict input validation Input whitelisting is enabled on all input portals to ensure that user input conforms to the expected type and format. 2. Use of parameterized queries All database queries are parameterized (e.g., precompiled statements) to avoid splicing user input. 3. Use secure database access libraries NET Core EF Core and JDBC. 4. CSP is enabled and CSRF is blocked on the web. 5. Key APIs have authentication enabled.
4.13	If user-facing, is the service compatible with Microsoft Edge and/or Google Chrome?	YES

5	Authentication & Access Control	
5.1	Does the service support single sign on through use of the client's internal IDP? (E.g., SAML2.0/OAuth on Microsoft Azure/SAP)	YES. Azure AD is fully tested. For other SSO providers, we will evaluate case-by-case
5.2	If SSO is supported, how can identities be provisioned? (E.g., SCIM)	ChemAIRS with Azure AD only supports pre-creation of users manually and validation of user login credentials via SSO, if SCIM or other requirements apply, we will evaluate case-by-case
5.3	Is multi-factor authentication available?	In development.
5.4	Which administrative functions performed by the vendor, and which are done by The client? Who has administrative access from the The client side?	Only user account creation will be performed by vendor.
5.5	What administrative protections are in place to safeguard against unauthorized use, modification, copying, accessing, or processing of data?	Please refer 3.6.
Questions 5.6 – 5.10 apply to non-client managed authentication methods		

5.6	How do users receive their credentials?	The business manager will communicate with the customer in advance and obtains the number of accounts and information required to be opened. After that, the business manager will submit the application for the internal process, the Ops platform will automatically create the corresponding user account and send the account information and initial password to the enterprise user to which the account belongs via e-mail.
5.7	What is the password policy? (E.g., complexity, expiry, etc.)	1. Password length can be at least 8 characters. 2. English uppercase, English lowercase, numbers and special characters, choose at least three of the four. 3. User account names, user email addresses, common simple passwords, or historical passwords are banned
5.8	How are password resets performed?	Exclusive tenant will be created before the creation of Enterprise users, one or more of the created users will be designated as the tenant administrator (usually before the creation of the business manager to communicate with the customer after the results), only the tenant administrator has the right to reset the password for the account under the tenant. In the unfortunate event that the Tenant Administrator's password is forgotten, the customer will need to submit a request via email, and the account management team will help reset it after the Business Manager verifies the account owner's information.
5.9	What is the account lockout policy?	User account will be locked after 5 incorrect entries
5.10	What is the process to remove a user? How long is the process expected to take?	Please refer to 3.8. Typically, it will take 1-3 weeks.

6	Subcontractors	
6.1	What subcontractors does your company use?	No subcontractors.
6.2	How do you ensure subcontractors maintain the same standards as described above?	Inapplicable.